

MÓDULO 2
Arquitecturas de seguridad
y técnicas
Ciberseguridad

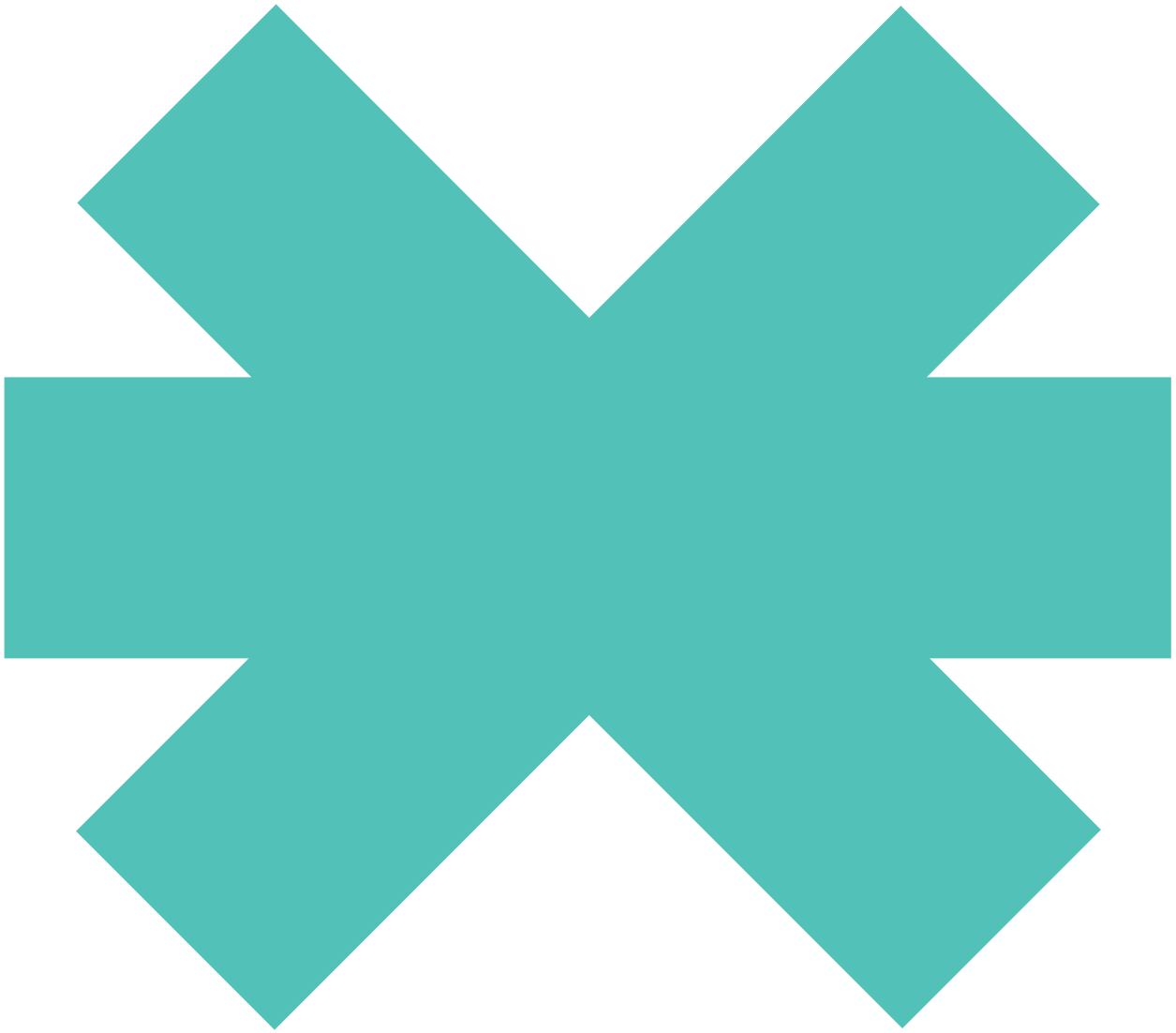
3

Amenazas inteligentes



New
Technology
School

Tokio.



3 Amenazas inteligentes

Sumario

3.1	¿Qué son?	134
3.2	Los sistemas SIEM	135
3.3	SOAR	137
3.4	Seguridad OSINT (<i>Open Source Intelligence</i>)	139

3.1 ¿Qué son?

Vivimos inmersos en un mundo que experimenta constantes cambios como consecuencia de la evolución tecnológica y de las nuevas vulnerabilidades que comporta.

De hecho, hace apenas 10 años, no se tenía en cuenta la seguridad digital en absoluto, de manera que resultaba muy sencillo llevar a cabo ataques cibernéticos. Además, a diferencia de lo que ocurre hoy en día, tampoco se accedía fácilmente al aprendizaje de estos aspectos, así que las brechas eran mucho más frecuentes.

Con los avances tecnológicos y la digitalización, han surgido nuevas amenazas y ha sido necesario adaptar la inteligencia humana a ellas. Para poder defendernos de los ataques, es imprescindible comprenderlos, ya que quienes los lanzan siempre van a ir un paso por delante de las defensas con las que contamos; por esta razón, resulta sumamente importante el análisis forense, así como ir aprendiendo de las nuevas amenazas.

Asimismo, en este contexto de permanente evolución, surgen las amenazas inteligentes, también conocidas como ciberamenazas avanzadas o amenazas persistentes avanzadas (APT, por sus siglas en inglés). Se trata de ataques cibernéticos dirigidos y extremadamente sofisticados que pretenden acceder de manera prolongada a sistemas o redes específicas con el propósito de extraer información sensible o realizar actividades maliciosas empleando una combinación de técnicas, herramientas y estrategias diseñadas para evadir los sistemas de seguridad tradicionales.

Veamos las principales características de las APT:

- **Dirigidas.** Han sido diseñadas para atacar objetivos específicos, como organizaciones, agencias gubernamentales, instituciones, etc., lo que requiere una investigación exhaustiva por parte de los atacantes, quienes recurren a técnicas de ingeniería social para identificar vulnerabilidades y puntos débiles.
- **Persistentes.** A diferencia de los ataques convencionales, las APT se gestan para prevalecer en el tiempo sin ser detectadas, permaneciendo ocultas durante meses o años.
- **Evasivas.** Estas amenazas suelen usar técnicas de evasión para evitar su detección por parte de los sistemas de seguridad tradicionales.
- **Objetivo de información sensible.** El principal objetivo de estas amenazas consiste en acceder a información sumamente sensible como secretos comerciales, propiedad intelectual, secretos de Estado, información estratégica, etc.

3.2 Los sistemas SIEM

Los sistemas SIEM (*Security Information and Event Management*) son aquellos que se implementan en las empresas y organizaciones encargadas de recopilar y, en numerosas ocasiones, de analizar y clasificar los datos que obtienen en tiempo real de los diferentes dispositivos que conforman una red. Se trata de sistemas que integran **tecnologías de gestión de eventos y de gestión de la información** dirigidas a proporcionar una **visión global del nivel de seguridad** y a **detectar posibles amenazas e incidentes**.

Por norma general, estos sistemas funcionan por medio de agentes que se instalan en los diferentes equipos y que envían datos a un servidor principal encargado de analizarlos en tiempo real para poder detectar las distintas amenazas en base a patrones de comportamiento.



Figura 6. Hacker explotando una vulnerabilidad. Fuente: Freepik.com

Las funciones principales que desempeña un sistema SIEM son:

- **Gestión de eventos.** Estos sistemas recopilan eventos de seguridad generados por diversos sistemas y dispositivos de red, como *firewalls*, IDS, IPS, servidores, aplicaciones y otros componentes. Normalmente, tales eventos incluyen registros de actividad, alertas, intentos de acceso no autorizado, etc.
- **Correlación de eventos.** Una vez recopilados los eventos, los sistemas SIEM emplean algoritmos y reglas para correlacionar y analizar los datos, lo que implica identificar patrones, relaciones y anomalías con el objeto de detectar posibles amenazas.
- **Gestión de información de seguridad.** Además de recopilar eventos en tiempo real, también reúnen información contextual adicional, como perfiles de usuarios/as, direcciones IP, información de activos, etc.
- **Gestión de logs.** Los sistemas SIEM almacenan y gestionan a largo plazo los registros de eventos de seguridad, lo que posibilita una revisión histórica y la realización de análisis forenses en caso de incidentes.

Generalmente, este tipo de herramientas son gestionadas por expertos en seguridad defensiva o preventiva en los centros de ciberseguridad denominados **SOC** (*Security Operations Center*), que se dividen en tres niveles:

- **N1.** Se trata del primer nivel dentro de un SOC y quienes lo gestionan se encargan de monitorizar los diferentes *logs* y de derivar los posibles reportes de incidencias de ciberseguridad que se generen al departamento pertinente para que pueda adoptar medidas. Este nivel de operativa no conlleva acciones sobre las amenazas.
- **N2.** Tras un período de experiencia como N1, los trabajadores y las trabajadoras que gestionan este nivel comienzan a participar activamente en la ciberseguridad de la organización y asumen responsabilidades de contramedida frente a los diferentes reportes que reciben del nivel anterior. Por lo general, configuran reglas de *firewalls* e investigan incidentes.
- **N3.** Dependiendo de la organización en la que se sitúe este nivel, quienes lo gestionan pueden encargarse de proporcionar una respuesta ante incidentes especializados, de atajar ataques en tiempo real o de establecer las defensas necesarias para evitar que un ataque prolifere. En muchas ocasiones, en este nivel se encuentra también el equipo de análisis forense.

Consideraciones de cara a la implementación de sistemas SIEM

La implementación de sistemas SIEM puede representar un desafío importante a la hora de garantizar su utilización efectiva y de fortalecer significativamente el nivel de seguridad. En este sentido, se requiere un análisis detallado de los requisitos y de las necesidades de la organización, lo que supone conocer los sistemas existentes, las fuentes de datos y los flujos de eventos para configurar correctamente el sistema SIEM.

Normalmente, se requiere de una **infraestructura de almacenamiento y procesamiento escalable**, dado que estos sistemas han de manejar grandes volúmenes de datos relativos a eventos de seguridad. En esta línea, deben definirse políticas adecuadas de retención de datos para adecuar las necesidades de almacenamiento a los requisitos normativos. Por tanto, también debe garantizarse **el mantenimiento y la actualización del sistema** aplicando parches y actualizaciones de *software* que permitan mantener las reglas y algoritmos al día para garantizar la eficacia del sistema. Paralelamente, ha de considerarse la **integración del sistema SIEM con otras soluciones de seguridad** implementadas en la organización, como IPS, sistemas de gestión de vulnerabilidades y sistemas de gestión de identidad y acceso.

Además, la implementación y gestión de un sistema SIEM requiere **personal cualificado** y con experiencia para manejarlo, configurarlo y mantenerlo, así como para interpretar y responder adecuadamente a las alertas generadas. Un monitoreo continuo, junto con revisiones periódicas de los eventos y alertas, permiten afinar el sistema SIEM y garantizar su precisión y relevancia de cara a la detección de amenazas.

3.3 SOAR

Otra solución de ciberseguridad relacionada con los sistemas SIEM, pero con un enfoque y una funcionalidad diferentes, es el SOAR (*Security Orchestration, Automation, and Response*), que comprende todas aquellas tecnologías que se utilizan para que las operaciones de seguridad resulten más eficientes, además de permitir la realización de tareas automatizadas.

El principal objetivo de SOAR consiste en **agilizar y optimizar la gestión de incidentes de seguridad**, posibilitando una respuesta más rápida y precisa a las amenazas. A diferencia de los sistemas SIEM, cuya función primordial es la recopilación, correlación y análisis de eventos de seguridad de diferentes fuentes, los sistemas SOAR se centran en la automatización y orquestación de respuestas a incidentes de seguridad. Esta solución, por tanto, **integra y automatiza tareas de seguridad** como la gestión de incidentes, la respuesta a amenazas, la recopilación de información y la coordinación de acciones entre diferentes herramientas de seguridad.

Veamos cuáles son las principales características y funcionalidades de un sistema SOAR:

- **Automatización de tareas.** Los sistemas SOAR permiten la automatización de tareas rutinarias y repetitivas destinadas a gestionar incidentes de seguridad, entre otras, la ejecución de acciones predefinidas, la recopilación de información, el análisis de registros o el bloqueo de direcciones IP sospechosas.
- **Orquestación de los flujos de trabajo.** Asimismo, estos sistemas permiten la creación y gestión de flujos de trabajo personalizables para coordinar y secuenciar las actividades de respuesta a incidentes, lo que contribuye a una gestión más eficiente de los equipos de seguridad al garantizar que las tareas se realizan en el orden correcto y en el momento adecuado.
- **Integración de herramientas de seguridad.** Un SOAR se puede integrar con diferentes herramientas y sistemas de seguridad como SIEM, sistemas de detección y prevención de intrusos, *firewalls* o sistemas de gestión de vulnerabilidades, entre otras.
- **Inteligencia y análisis de amenazas.** Estos sistemas pueden recurrir a fuentes de inteligencia de amenazas, como *feeds* de vulnerabilidades y amenazas conocidas, para enriquecer el análisis y la respuesta a los incidentes. De este modo, contribuyen a identificar rápidamente las amenazas y proporcionan información valiosa de cara a la toma de decisiones y a la implementación de medidas correctivas.
- **Informes y métricas.** Los SOAR generan informes y métricas sobre la gestión de incidentes, ofreciendo una visión clara del estado de seguridad y permitiendo evaluar el rendimiento de los equipos de respuesta. Estos informes pueden resultar útiles para fines de auditoría y cumplimiento normativo.

Aunque los sistemas SOAR presentan una serie de ventajas que repercuten significativamente en la seguridad de una organización, también poseen algunos inconvenientes que conviene valorar, como su elevado coste de implementación o el tiempo requerido para aprender a manejarlo y a configurar la automatización de tareas. Además, en ciertos casos, muchos equipos SOAR requieren de programación y gran parte de las empresas no cuentan con los profesionales adecuados para llevar a cabo esta labor.

Diferencias entre SIEM y SOAR

Como hemos visto hasta ahora, tanto los sistemas SIEM como los SOAR son soluciones de seguridad adecuadas para implementar en una organización. No obstante, ya hemos señalado que ambos sistemas presentan enfoques y funcionalidades diferentes.

Aunque los sistemas SIEM también cuentan con la capacidad de proporcionar cierta automatización, su principal función es la recopilación y análisis de eventos de seguridad, mientras que los SOAR se centran en la automatización y orquestación de tareas de seguridad, ofreciendo una respuesta automatizada a los incidentes.

Por otro lado, los sistemas SIEM presentan mayores limitaciones a la hora de integrarse con otras herramientas y sistemas de seguridad, en tanto que los sistemas SOAR permiten coordinar y orquestar acciones entre una amplia gama de soluciones. Así, los SOAR pueden integrarse con SIEM, *firewalls*, IPS, IDS y con sistemas de gestión de vulnerabilidades.

3.4 Seguridad OSINT (*Open Source Intelligence*)

También conocida como Inteligencia de Fuentes Abiertas, se trata de un conjunto de herramientas y técnicas destinadas a la recopilación, análisis y uso de la información procedente de fuentes de acceso público con el objeto de obtener y generar conocimiento relevante.

A diferencia de las fuentes cerradas, de carácter confidencial o restringido, las fuentes abiertas incluyen información disponible públicamente en internet, bases de datos, medios de comunicación, redes sociales, sitios web, foros y cualquier otra fuente de acceso abierto.

Uno de los aspectos clave de OSINT reside en la forma de reunir información, pues busca y selecciona aquella que resulta relevante en fuentes abiertas recurriendo a técnicas y herramientas adecuadas, lo que implica explorar la web, usar motores de búsqueda avanzados, rastrear redes sociales, extraer datos de documentos públicos, etc.

Paralelamente, se evalúa y procesa la información reunida para extraer el conocimiento realmente útil y relevante. En este sentido, se ha de verificar la autenticidad y confiabilidad de la información realizando un análisis del contenido para identificar patrones y relaciones. Posteriormente, los datos recopilados se transforman en conocimiento significativo al que recurrir para adoptar decisiones informadas y anticiparse a posibles amenazas.

Principales funciones de OSINT

OSINT posee aplicaciones en los siguientes campos:

- **Investigación.** Este sistema se utiliza en investigaciones criminales, legales y de inteligencia para recopilar información sobre personas, organizaciones, eventos o situaciones específicas, contribuyendo a una comprensión más profunda y precisa de los sujetos de investigación.
- **Seguridad cibernética.** Del mismo modo, desempeña un papel crucial en la identificación y evaluación de posibles amenazas cibernéticas, permitiendo monitorear y reunir información sobre actores maliciosos, técnicas de ataque, vulnerabilidades y otros aspectos relacionados con la seguridad en línea.
- **Inteligencia empresarial y competitiva.** Las organizaciones utilizan OSINT para recopilar información sobre sus competidores, clientes, proveedores y otros actores relevantes de su sector, lo que permite tomar decisiones estratégicas, identificar oportunidades de mercado y anticipar cambios en el entorno empresarial.
- **Gestión de riesgos.** OSINT también se utiliza para monitorear y analizar posibles riesgos y amenazas en diferentes ámbitos, entre ellos, la seguridad nacional, la gestión de crisis, la evaluación de riesgos de inversión y la seguridad de viajes.

REDES SOCIALES

Las redes sociales como Facebook, Twitter, LinkedIn, Instagram o YouTube constituyen fuentes ricas en información, ya que muchos usuarios y usuarias comparten su día a día en ellas, mantienen visibles sus contactos y publican sus gustos y preferencias. Estas plataformas proporcionan acceso a perfiles de usuarios/as, a publicaciones, a conexiones, a intereses y a otros datos relevantes a la hora de reunir información.

Paralelamente, herramientas como Hootsuite, TweetDeck, Brandwatch o Talkwalker permiten monitorizar y rastrear en tiempo real conversaciones en redes sociales, así como identificar tendencias y realizar un seguimiento de las menciones de marcas o de personas específicas.

HERRAMIENTAS DE INTELIGENCIA DE DOMINIO PÚBLICO

En este campo, podemos referirnos a Maltego, Recon-ng y SpiderFoot, que automatizan la recopilación de información y el análisis de fuentes abiertas. Estas herramientas permiten rastrear las IP, los nombres de dominio, los correos electrónicos y los nombres de usuario/a, además de generar visualizaciones gráficas de la información reunida.

HERRAMIENTAS DE ANÁLISIS DE DATOS

Plataformas como IBM i2 Analyst's Notebook, Palantir y Maltego ofrecen capacidades avanzadas de análisis y visualización de datos que permiten conectar y correlacionar información de diferentes fuentes para identificar patrones y relaciones ocultas.

HERRAMIENTAS DE BÚSQUEDA DE ARCHIVOS

Aplicaciones como Shodan y Censys permiten buscar dispositivos conectados a internet, como servidores, cámaras de seguridad y sistemas de control industrial, proporcionando información sobre vulnerabilidades y configuraciones expuestas.